

✓ Vulnerability Assessment Report on [out-dated kali machine]

Target: Kali Linux Outdated (Created For This Testing)

Tool Used: Greenbone Vulnerability Management (OpenVAS)

Scan Type: Full and Fast

Scan Date: [04/08/2025]

Overview

This report summarizes the vulnerabilities identified on the Kali Linux machine during an OpenVAS scan. The scan focused on detecting misconfigurations, exposed services, outdated software, and potential exploit vectors. The objective is to evaluate the system's security posture and provide actionable recommendations for mitigation.

Scan Summary

Category	Value
Target IP	192.168.0.104
Operating System	Kali Linux (Rolling)
Total Vulnerabilities	9
High Risk	2
Medium Risk	4
Low Risk	3
CVEs Identified	CVE-2019-6111, CVE-2021-4034, etc.
Ports Scanned	1-65535

High Risk Vulnerabilities

1. OpenSSH User Enumeration Vulnerability (CVE-2018-15473)

- **Risk:** High
- **Description:** The OpenSSH server allows an attacker to determine valid usernames on the system by analyzing response behavior.

- **Recommendation:**

- Update OpenSSH to the latest version.
 - Consider disabling SSH password authentication and use key-based authentication.
 - Set MaxAuthTries to a lower number in /etc/ssh/sshd_config.
-

2. Polkit Privilege Escalation (CVE-2021-4034)

- **Risk:** High

- **Description:** A local privilege escalation vulnerability (PwnKit) in Polkit allows a low-privilege user to gain root access.

- **Recommendation:**

- Update the polkit package immediately:
 - `sudo apt update && sudo apt install --only-upgrade policykit-1`
-

● Medium Risk Vulnerabilities

3. SMBv1 Enabled

- **Risk:** Medium

- **Description:** The SMBv1 protocol is outdated and insecure.

- **Recommendation:**

- Disable SMBv1 protocol.
 - Use SMBv2 or higher by configuring /etc/samba/smb.conf.
-

4. Apache Web Server Exposes Version Information

- **Risk:** Medium

- **Description:** Apache headers expose version info, which may aid attackers.

- **Recommendation:**

- Hide version details by editing /etc/apache2/conf-enabled/security.conf:
- ServerTokens Prod
- ServerSignature Off

5. Outdated Nginx Detected

- **Risk:** Medium
 - **Description:** The version installed contains known security issues.
 - **Recommendation:**
 - Upgrade Nginx using:
 - `sudo apt update && sudo apt install nginx`
-

6. Insecure ICMP Configuration

- **Risk:** Medium
 - **Description:** ICMP responses may reveal internal network structure.
 - **Recommendation:**
 - Use iptables or UFW to restrict unnecessary ICMP traffic:
 - `sudo iptables -A INPUT -p icmp --icmp-type echo-request -j DROP`
-

Low Risk Vulnerabilities

7. SSH Root Login Enabled

- **Risk:** Low
- **Recommendation:**
 - Disable root login in SSH by editing:
 - `PermitRootLogin no`

8. FTP Server Detected (Anonymous Login Disabled)

- **Risk:** Low
- **Recommendation:**
 - Confirm FTP is needed; if not, disable the service.
 - If needed, consider switching to SFTP.

9. Deprecated TLS Versions Supported

- **Risk:** Low
 - **Recommendation:**
 - Configure SSL/TLS to support only TLS 1.2 and 1.3.
-

General Recommendations

- Apply regular OS updates:
 - `sudo apt update && sudo apt upgrade -y`
 - Use a host-based firewall (e.g., UFW) to restrict unnecessary ports:
 - `sudo ufw enable`
 - `sudo ufw allow ssh`
 - `sudo ufw deny 21`
 - Remove or disable unused services and daemons.
-

Conclusion

The assessment revealed multiple vulnerabilities ranging from low to high severity. Immediate attention is required for high-risk issues like **Polkit and OpenSSH enumeration**. Mitigating these risks will significantly improve the security posture of the system.
